

Détection d'attaques par analyse de trames

Source cisco - cyberops

Objectif : à l'aide des **CINQ** différents fichiers Wireshark (Pcapng), nous vous demandons d'analyser différentes situations présentant des signes de compromission du Système d'Information.

Les cas étudiés seront les suivants :

- 1) Tentative d'accès externes sur nos machines
- 2) Téléchargement suspect
- 3) Communication non autorisée sur le réseau
- 4) Détection de flux non autorisés sur notre réseau et identification de l'utilisateur.
- 5) Analyse de Tier 2 suite à la détection d'une activité suspecte par l'équipe du Tier 1

Pour chaque cas, vous disposerez d'un fichier spécifique contenant les informations recherchées.

Votre travail consiste à analyser le contenu des trames de la capture pour comprendre quelle type de communication on peut y trouver.

En particulier : vous êtes conduits à utiliser l'outil **FILTRE** de Wireshark.

Le cas N°1 vous montre comment **utiliser** un élément intéressant d'une trame particulière pour produire un filtre qui cherchera toutes les trames qui contiennent le même élément.

Notez alors **comment s'écrit** ce filtre Wireshark. Pour pouvoir en écrire vous-même d'autres sur le même modèle

On attend une explication **détaillée** de la façon dont vous trouvez la réponse aux question posées. N'hésitez pas à utiliser des copies d'écran pour nous permettre de VOIR ce qui vous permet d'avancer dans votre analyse.

Nota : Le réseau Interne de l'entreprise a pour adresse 24.6.0.0/16

Que nous dit de l'entreprise cette adresse de réseau ?

...

Cas n°1 : Tentatives d'accès externe.

Le fichier **cas1.pcapng** contient la capture du trafic.

Lorsqu'un hôte externe tente de se connecter sur un poste, il initie le processus de connexion TCP (Three Way Handshake).

- Placez-vous sur la 1^{ère} trame et développez la zone TCP.
- Localisez la valeur du Flag TCP qui initie le SYN.
- Appliquez-le en tant que filtre (Clic droit sur l'expression, **Appliquer en tant que filtre Sélectionné**)

Cette opération permettra de voir toutes les tentatives d'ouverture de session.

Q1.1 Combien de tentatives d'ouverture de session recensez-vous ?

Il y a 42 tentatives d'ouverture de session

The screenshot shows the Wireshark interface. On the left, the 'Flags: 0x0002 (SYN)' field is expanded, showing the bit fields for SYN, ACK, RST, etc. On the right, a context menu is open with 'Appliquer comme un Filtre' selected. Below the menu, the filter 'tcp.flags == 0x0002' is shown. At the bottom, the packet list shows 575 packets, with 42 highlighted in blue, representing the SYN packets.

Paquets : 575 · Affichés : 42 (7.3%)

Pour savoir si des tentatives de connexions vers notre réseau ont eu lieu, ajoutez au filtre existant un filtre pour l'IP de destination dans notre réseau.

Pour ajouter une condition à un filtre pensez à l'opération booléenne ET

Q1.2 Quel est maintenant le nouveau filtre ? **(tcp.flags == 0x0002) && (ip.dst == 24.6.0.0/16)**

Q1.3 Quelle est l'adresse IP de l'hôte qui a initié ce flux ? **121.125.72.180**

Vers quels hôte interne ? **24..169.43 et 24.6.72.173.220**

Quelle est l'adresse IP de l'hôte distant et quelle est sa localisation ?

L'adresse de l'hôte distante est 121.125.72.180 et sa localisation est en Corée du sud dans Séoul

Réalisez les mêmes opérations sur le fichier **Cas1bis.pcapng**

Identifier la tentative de connexion externe.

Q1.4 Quelle est l'adresse IP de l'hôte qui a initié ce flux ? **183.63.31.122**

Vers quels hôtes internes ? **24.6.173.200**

Quelle est l'adresse IP de l'hôte distant et quelle est sa localisation ? **183.63.31.122 qui se trouve en Chine à Huizhou.**

Quel est le protocole utilisé dans la tentative de connexion ? **TCP**

Que pouvez-vous en conclure ? **Il y a eu des tentatives de connexion venant de Corée et de Chine vers le réseau interne**

Cas n°2 : Téléchargement suspect.

Le fichier **cas2.pcapng** contient la capture du trafic.

Vous soupçonnez qu'un utilisateur a voulu télécharger un fichier d'analyse réseau à partir de son poste. Vous rechercherez dans la capture toutes les demandes de fichiers exécutables (exe).

- Ouvrez le fichier cas2.pcapng.
- Recherchez dans la capture les requêtes http qui contiennent l'expression .exe (TIPS utilisez l'expression régulière contains)

http contains ".exe"

http contains ".exe"						
No.	Time	Source	Destination	Protocol	Length	Info
211	5.818795	24.6.181.160	107.6.133.250	HTTP	755	GET /data/releases/metasploit-latest-windows-installer.exe HTTP/1.1

Q2.1 Dans quelle trame avez-vous trouvé cette expression ? 211

Quel est le nom du fichier téléchargé ? metasploit-latest-windows-installer.exe

Identifier la machine source et destination La machine source est 24.6.181.160 qui télécharge vers 107.6.133.250

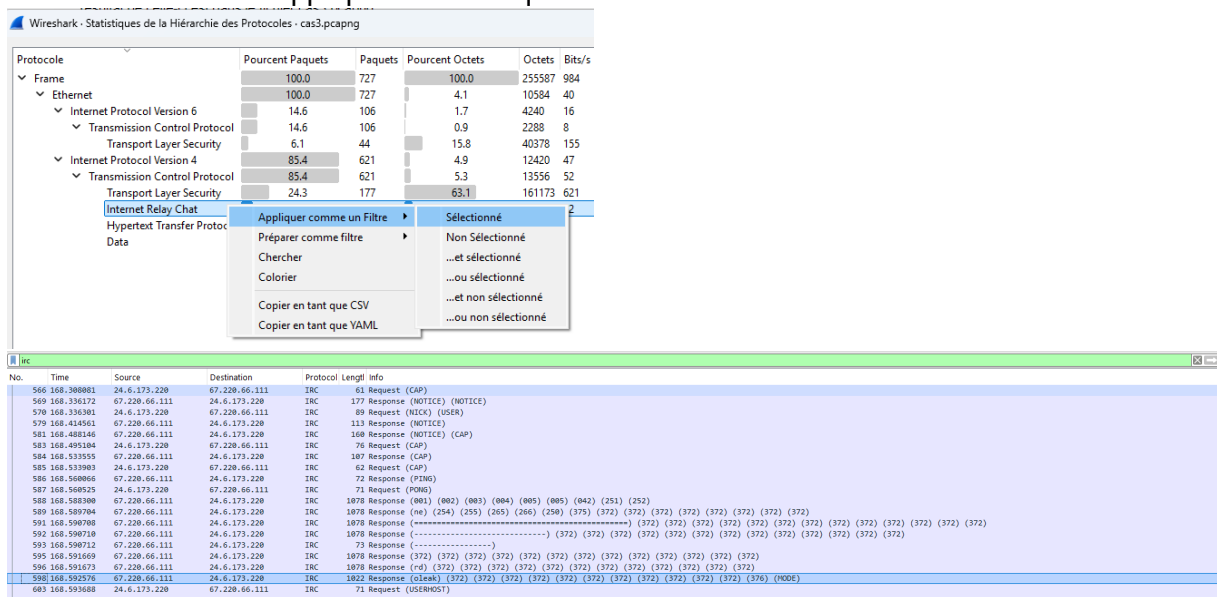
Cas n°3 : Communication non autorisée sur le réseau.

Le fichier **cas3.pcapng** contient la capture du trafic.

Vous soupçonnez un utilisateur d'utiliser un logiciel de communication IRC (Internet Relay Chat) sur le réseau de l'entreprise ce qui est interdit dans la charte informatique.

Vous réalisez une capture du trafic pour identifier la personne à l'origine de ce flux. Le résultat de celle-ci est dans le fichier cas3.pcapng

- À l'aide de la commande **Statistiques, Hiérarchie des Protocoles** identifiez le flux suspect.
- Isolez-le en l'appliquant en tant que filtre.



Cas n°4 : Tentative d'accès.

Le fichier **cas4.pcapng** contient la capture du trafic.

Nous avons capturé une tentative d'accès sur un serveur de fichiers. Vous la trouverez dans le fichier cas4.pcapng

Q4.1 Identifiez le poste serveur et le poste client.

Poste client : 10.234.125.254

Serveur : 10.121.70.151

Nous pouvons remarquer de nombreuses tentatives de connexions.

Q4.2 Quel est le type d'attaque initiée par le client ? **Brute force, il tente des mots de passes sur le compte admin**

Combien de tentatives ont été réalisées ?

(tcp.flags == 0x0010) && (ip.src == 10.234.125.254) && (ip.dst == 10.121.70.151)

(tcp.flags == 0x0010) && (ip.src == 10.234.125.254) && (ip.dst == 10.121.70.151)						
No.	Time	Source	Destination	Protocol	Length	Info
3	0.007741	10.234.125.254	10.121.70.151	TCP	60	2227 → 21 [ACK] Seq=1 Ack=1 Win=17520 Len=0
6	0.013244	10.234.125.254	10.121.70.151	TCP	60	2228 → 21 [ACK] Seq=1 Ack=1 Win=17520 Len=0
24	0.091926	10.234.125.254	10.121.70.151	TCP	60	2217 → 21 [ACK] Seq=2 Ack=24 Win=17447 Len=0
28	0.104155	10.234.125.254	10.121.70.151	TCP	60	2220 → 21 [ACK] Seq=2 Ack=24 Win=17447 Len=0
37	0.141939	10.234.125.254	10.121.70.151	TCP	60	2222 → 21 [ACK] Seq=15 Ack=58 Win=17447 Len=0
41	0.147316	10.234.125.254	10.121.70.151	TCP	60	2221 → 21 [ACK] Seq=16 Ack=58 Win=17447 Len=0
45	0.190754	10.234.125.254	10.121.70.151	TCP	60	2223 → 21 [ACK] Seq=13 Ack=58 Win=17447 Len=0
55	0.215503	10.234.125.254	10.121.70.151	TCP	60	2229 → 21 [ACK] Seq=1 Ack=1 Win=17520 Len=0
61	0.246378	10.234.125.254	10.121.70.151	TCP	60	2230 → 21 [ACK] Seq=1 Ack=1 Win=17520 Len=0
64	0.252109	10.234.125.254	10.121.70.151	TCP	60	2231 → 21 [ACK] Seq=1 Ack=1 Win=17520 Len=0
66	0.257535	10.234.125.254	10.121.70.151	TCP	60	2232 → 21 [ACK] Seq=1 Ack=1 Win=17520 Len=0
71	0.267290	10.234.125.254	10.121.70.151	TCP	60	2233 → 21 [ACK] Seq=1 Ack=1 Win=17520 Len=0
84	0.349133	10.234.125.254	10.121.70.151	TCP	60	2224 → 21 [ACK] Seq=12 Ack=58 Win=17447 Len=0
87	0.386847	10.234.125.254	10.121.70.151	TCP	60	2234 → 21 [ACK] Seq=1 Ack=1 Win=17520 Len=0
114	0.500871	10.234.125.254	10.121.70.151	TCP	60	2227 → 21 [ACK] Seq=29 Ack=75 Win=17447 Len=0

Il y a 2834 tentative de connexion

Cas n°5 : Analyse Tier 2

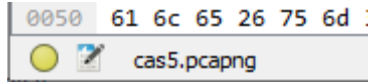
Le fichier **cas5.pcapng** contient la capture du trafic.

Un de vos collègues du Tier1 soupçonne une redirection de flux.

Il vous adresse la capture réalisée (fichier cas5.pcapng).

Il a commenté le fichier.

- Pour accéder aux commentaires, utilisez le bouton expert



- Dans la zone « comment » vous retrouvez l'ensemble des paquets commentés.
- Placez-vous sur la première trame puis consultez les annotations.
- Analysez les commentaires puis **retrouvez la redirection**.

Q5.1 Détaillez votre réponse concernant cette analyse des commentaires et la redirection soupçonnée.

Il ne s'agit pas de réécrire les commentaires mais de **vous servir** des commentaires pour retrouver dans les différentes trames le détail des échanges qui permettra de dire si le soupçon de vos collègues est bien justifié.